

TUGAS PERTEMUAN 5
AUDIT SISTEM INFORMASI



Disusun oleh:

Rama Pramudya Wibisana

2022320019

PROGRAM STUDI SISTEM INFORMASI

FAKULTAS INFORMATIKA

UNIVERSITAS BINA INSANI

BEKASI

2024

A. I.T.I.L (*Information Technology Infrastructure Library*)

ITIL adalah kelompok praktik terbaik untuk mengelola layanan TI (Teknologi Informasi). Pada dasarnya, ITIL membantu perusahaan menjaga sistem TI mereka berjalan lancar dan selalu memenuhi kebutuhan bisnis. ITIL juga menjamin bahwa proses perbaikan sistem akan jelas dan cepat.

ITIL terdiri dari lima tahap utama yang dikenal sebagai Service Lifecycle. Setiap tahap memiliki fokus khusus dalam pengelolaan layanan TI.

1. Service Strategy (Strategi Layanan)

- Fokus pada mengembangkan strategi layanan yang tepat untuk mendukung tujuan bisnis.
- Mencakup pengelolaan keuangan, manajemen risiko, dan pengembangan nilai bagi pelanggan.
- Tujuan: Memastikan layanan TI yang disediakan relevan dengan kebutuhan bisnis dan dapat memberikan nilai maksimal.

2. Service Design (Desain Layanan)

- Merancang layanan TI berdasarkan strategi yang telah ditetapkan.
- Fokus pada membangun layanan TI yang sesuai dengan ekspektasi bisnis, termasuk infrastruktur, keamanan, dan katalog layanan.
- Tujuan: Membuat layanan yang siap untuk dioperasikan dengan mempertimbangkan performa, keamanan, serta kemudahan penggunaannya.

3. Service Transition (Transisi Layanan)

- Memastikan bahwa layanan yang baru dirancang dapat diimplementasikan dengan lancar ke dalam operasional bisnis.
- Melibatkan proses Change Management, Configuration Management, dan Release Management.
- Tujuan: Mentransisikan layanan baru tanpa gangguan besar kepada pengguna atau bisnis.

4. Service Operation (Operasi Layanan)

- Berfokus pada pengelolaan layanan sehari-hari yang digunakan oleh pelanggan dan pengguna.
- Proses-proses inti seperti Incident Management (menangani gangguan layanan), Problem Management (mengatasi akar masalah), dan Service Request Management.
- Tujuan: Memastikan layanan TI yang sudah berjalan berfungsi dengan optimal dan memberikan nilai yang dijanjikan kepada pelanggan.

5. Continual Service Improvement (Perbaikan Layanan Berkelanjutan)

- Berfokus pada perbaikan terus-menerus atas layanan yang disediakan.
- Melakukan evaluasi secara berkala terhadap kinerja layanan dan proses untuk menemukan peluang perbaikan.
- Tujuan: Meningkatkan kualitas layanan berdasarkan pengalaman pengguna dan perubahan kebutuhan bisnis.

Contoh Kasus ITIL:

Misalkan sebuah perusahaan perbankan ingin memastikan bahwa layanan pembayaran online mereka aman dan selalu tersedia. ITIL membantu mereka dalam:

- Merancang layanan Internet Banking yang aman dan mudah digunakan melalui tahap desain layanan
- Mengelola perubahan perangkat lunak secara bertahap melalui transisi layanan
- Mengatasi masalah operasional seperti down server melalui manajemen insiden dalam operasional layanan
- Terus mengevaluasi dan meningkatkan fitur layanan melalui peningkatan terus menerus layanan.

B. COBIT (*Control Objectives for Information and Related Technologies*)

COBIT adalah framework untuk tata kelola TI. Secara khusus, COBIT membantu perusahaan memastikan bahwa teknologi yang mereka gunakan sesuai dengan tujuan bisnis mereka. Selain itu, COBIT memastikan bahwa pengelolaan teknologi berjalan dengan efektif dan bahwa performanya dapat diukur.

COBIT 2019 dibagi menjadi dua bagian besar, yaitu Governance dan Management. Di dalamnya terdapat 40 proses yang terbagi dalam beberapa domain:

1. Governance (EDM - Evaluate, Direct, and Monitor)

- Menyediakan arahan strategis, mengawasi hasil, dan memastikan bahwa penggunaan TI mendukung tujuan bisnis.
- Tujuan: Memastikan bahwa keputusan TI diselaraskan dengan kebutuhan bisnis dan memonitor kinerja TI secara keseluruhan.

2. Management

1. APO (Align, Plan, and Organize)

- Proses untuk menyelaraskan TI dengan strategi bisnis dan merencanakan implementasi TI.
- APO07: Mengelola sumber daya manusia TI, memastikan mereka memiliki keterampilan yang tepat.

2. BAI (Build, Acquire, and Implement)

- Fokus pada proses untuk membangun dan mengimplementasikan solusi TI baru.
- BAI02: Mengelola definisi persyaratan untuk solusi TI baru.

3. DSS (Deliver, Service, and Support)

- Mengelola penyampaian layanan TI ke pengguna.
- DSS05: Mengelola layanan keamanan untuk melindungi aset informasi organisasi.

4. MEA (Monitor, Evaluate, and Assess)

- Proses untuk mengevaluasi kinerja TI dan memantau apakah TI berjalan sesuai harapan.
- MEA01: Memantau dan mengevaluasi kinerja layanan TI serta kepatuhannya terhadap kebijakan.

Contoh Kasus COBIT:

Untuk memastikan bahwa mereka memanfaatkan TI secara efektif, sebuah perusahaan telekomunikasi besar menggunakan COBIT dan proses APO07. Mereka juga memastikan bahwa staf TI memiliki keterampilan yang sesuai dengan teknologi yang mereka gunakan. DSS05 mengelola keamanan data pelanggan, termasuk mencegah peretasan. Selain itu, mereka menggunakan MEA01 untuk melacak kinerja sistem TI dan memastikan bahwa semuanya berjalan sesuai harapan manajemen.

C. ISO/IEC 27001, 27002, 27003, dan 20000

ISO/IEC 27001

Standar ini berpusat pada sistem manajemen keamanan informasi (ISMS). ISO/IEC 27001 bertujuan untuk membantu organisasi menerapkan pendekatan berbasis risiko untuk melindungi data sensitif mereka dari ancaman dari sumber eksternal dan internal.

- Tujuan: Mengidentifikasi risiko keamanan informasi, merancang kontrol yang sesuai, dan memastikan informasi tetap aman.
- Komponen utama: Mengelola aset informasi, risiko, dan implementasi kontrol keamanan (misalnya, enkripsi, kontrol akses, kebijakan keamanan).

ISO/IEC 27002

ISO/IEC 27002 menguraikan langkah-langkah teknis yang lebih rinci untuk mendukung penerapan ISO/IEC 27001 dan berfungsi sebagai pedoman untuk memilih dan menerapkan kontrol keamanan berdasarkan praktik terbaik.

ISO/IEC 27003

Ini adalah pedoman untuk pelaksanaan ISO/IEC 27001. ISO/IEC 27003 membantu organisasi memahami cara merancang, membangun, dan mengelola sistem manajemen keamanan informasi (ISMS) yang sesuai dengan ISO/IEC 27001.

ISO/IEC 20000

Standar ini serupa dengan ITIL dalam hal pengelolaan layanan TI, tetapi ISO/IEC 20000 memberikan panduan untuk perusahaan agar mampu memberikan layanan TI yang berkualitas dengan mengelola aspek-aspek operasional layanan secara efektif.

- Tujuan: Menyediakan layanan TI yang sesuai dengan kebutuhan bisnis dan pelanggan.
- Standar ini sering digunakan oleh penyedia layanan TI yang ingin menunjukkan bahwa mereka memenuhi standar global dalam pengelolaan layanan.

Contoh Kasus ISO/IEC 27001:

Sebuah startup e-commerce ingin menjaga data pelanggan, termasuk informasi pribadi dan detail pembayaran, aman. Untuk melindungi data pelanggan dari serangan cyber, perusahaan menerapkan kontrol keamanan seperti enkripsi data sesuai dengan ISO/IEC 27001. Selain itu, mereka membatasi akses ke data hanya kepada karyawan yang berwenang dan melakukan audit keamanan rutin, meningkatkan perlindungan data dan kepercayaan pelanggan.